

AI Security Procurement Checklist

A practical buyer checklist for evaluating AI vendors, model services, assistants, and agent platforms before contract and launch.

How to use this resource

Assign one accountable owner, work through each section with security, legal, procurement, IT, and the business sponsor, then save decisions and evidence with the vendor or AI program record.

1. Vendor and service boundary

Define exactly what is being purchased before evaluating controls.

- ☐ Name the service owner, business sponsor, intended users, and approved workflows.
- ☐ List model providers, subprocessors, hosting regions, support access, and external connectors.
- ☐ Document whether customer data, employee data, source code, credentials, or regulated data may enter the service.
- ☐ Record contract term, renewal date, pricing basis, data-use terms, and an exit path.

2. Identity and access

Access should follow company identity, least privilege, and lifecycle controls.

- ☐ Require SSO for workforce access and MFA for privileged administration.
- ☐ Map roles to approved models, tools, data classes, and administrative actions.
- ☐ Test joiner, mover, leaver, dormant-account, break-glass, and service-account processes.
- ☐ Confirm access logs show who changed policy, routing, retention, and connector settings.

3. Data protection and retention

Decide what the service can receive, store, reuse, and disclose.

- ☐ Confirm encryption in transit and at rest, key ownership, backup scope, and deletion behavior.

- [] Define prompt, response, file, embedding, log, support, and backup retention separately.
- [] Verify whether inputs or outputs are used for model training, product improvement, or human review.
- [] Test redaction, export, deletion, legal hold, regional routing, and tenant isolation.

4. AI-specific security

Evaluate risks created by prompts, models, retrieval, agents, and tools.

- [] Test prompt injection, sensitive data disclosure, unsafe output, excessive agency, and resource abuse.
- [] Require allowlisted tools, scoped credentials, outbound controls, and approval for high-impact actions.
- [] Record model changes, system instructions, retrieval sources, policy events, tool calls, and overrides.
- [] Define quality, safety, security, and cost thresholds with a rollback process.

5. Assurance and incident readiness

Evidence should be reviewable before launch and during operation.

- [] Review independent assurance, penetration testing scope, vulnerability handling, and remediation timelines.
- [] Agree notification timelines, investigation support, evidence preservation, and customer communication duties.
- [] Run an incident tabletop covering data exposure, compromised credentials, harmful output, and provider outage.
- [] Set an approval decision, open risks, compensating controls, owner, due date, and review cadence.

Reference frameworks

Use the latest applicable versions and confirm legal requirements with qualified counsel for your jurisdiction and use case.

NIST AI Risk Management Framework: <https://www.nist.gov/itl/ai-risk-management-framework>

NIST Cybersecurity Framework 2.0: <https://www.nist.gov/cyberframework>

OWASP Top 10 for LLM Applications: <https://owasp.org/www-project-top-10-for-large-language-model-applications/>

ISO/IEC 42001 overview: <https://www.iso.org/standard/81230.html>